SOCIAL ENGINEERING & PHISHING CAMPAIGN SIMULATION

A Practical Lab Report for GRC Professionals

Prepared by: Oluwatosin Olajubu
Registration number: C11/26/CGRCE/217602

Lab: Q3 GRC Phishing Simulation
Environment: Kali Linux, GoPhish and Mailtrap sandbox (local laboratory)

1. Introduction

This report documents how I completed a controlled phishing-awareness simulation using GoPhish. The purpose of the exercise was to understand how a phishing campaign is prepared, delivered and measured, and how the resulting evidence can be interpreted from a Governance, Risk and Compliance (GRC) perspective.

I used Kali Linux as the lab environment, GoPhish to configure and manage the campaign, and Mailtrap as the test email service. The exercise used a limited test group and a fictional VPN password-reset scenario. The campaign was intended for controlled testing, not for targeting members of the public or collecting real organisational credentials.

2. Lab Environment and Tools

Laboratory setup: the simulation ran entirely on my local computer. A Kali Linux virtual machine hosted GoPhish (administration interface on 127.0.0.1:3333) and the campaign tracking and landing-page server. Mailtrap acted as an email sandbox, so no message left the controlled environment. Only a mailbox I control, fictional identities and a fictional training login page were used; no real users or real credentials were involved.

- Kali Linux virtual machine – used to run GoPhish and access the campaign interface.
- GoPhish – used to create the sending profile, landing page, email template, recipient group and campaign.
- Mailtrap – used as the controlled SMTP service and test inbox for receiving the simulated email.
- Firefox – used to access the GoPhish interface, Mailtrap and the campaign tracking link.
- Fictional VPN scenario – used as the theme for the simulated password-reset email and landing page.

3. Phase 1: Setup and Preparation

Step 1: Installing and starting GoPhish

I began by preparing the GoPhish application in Kali Linux. I downloaded the GoPhish Linux archive, extracted the files into a GoPhish folder, changed into that directory and made the executable runnable. I then started GoPhish from the terminal and accessed its web interface through the local browser.

The commands used for the installation and launch were:

```
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip

unzip gophish-v0.12.1-linux-64bit.zip -d gophish/

cd gophish/

chmod +x gophish

./gophish
```

Once the application was running, I opened the GoPhish administration interface at https://127.0.0.1:3333 and proceeded to configure the campaign.

Step 2: Configuring the Mailtrap Sending Profile

I accessed the Sending Profiles section in GoPhish and created a profile named “Mailtrap Test”. I used the SMTP host, port, username and password provided by my Mailtrap account. This connected GoPhish to the controlled test-mail service. I then used Mailtrap to verify that the test email could be received successfully.

Step 3: Creating the Fake VPN Portal Landing Page

I created a landing page named “Fake VPN Portal”. The page used a fictional SecureConnect VPN theme to represent an internal remote-access portal. I configured the page as the destination for the link in the simulated

password-reset email. The page was configured to record a form-submission event as evidence of interaction. The test was restricted to the designated lab test group and test mailbox; real organisational users and production credentials were not in scope. Based on the brief with password capture enabled; no credentials were entered, no submissions were recorded, and the setting should be disabled in future runs.

The landing-page exercise demonstrated how a link in a phishing email can direct a recipient to a web page that resembles a familiar service. It also highlighted why organisations should verify unexpected login prompts and inspect website addresses before entering information.

Step 4: Creating the Email Template

I created an email template named “VPN Password Reset Required”. I used the subject line “Action Required: Your VPN Password Expires in 24 Hours”. The message presented a fictional VPN password-expiry notice and included the GoPhish tracking placeholder {{.URL}}. I also retained the {{.FirstName}} variable so that GoPhish could personalise the greeting for the test recipient.

Step 5: Defining the Target Group

I created a recipient group named “Lab Test Group” and added the designated test mailbox. I used the test recipient details rather than a list of real employees. This kept the exercise within the controlled scope of the practical.

4. Phase 2: Launching the Campaign

Step 6: Configuring and launching the campaign

I created a campaign named “Q3 GRC Phishing Simulation” and selected the email template, landing page, Mailtrap sending profile and Lab Test Group. GoPhish required a campaign URL so that it could generate the tracking link used to record recipient interactions. I configured the local test URL and sent the campaign to the test mailbox.

After sending, I opened Mailtrap and located the simulated VPN password-reset email. The tracking URL was displayed in the email content. It was not presented as a clickable link in the Mailtrap view, so I copied the complete URL, including its unique rid tracking parameter, and opened it in a new Firefox tab within Kali Linux. GoPhish then recorded the interaction.

5. Phase 3: Monitoring and Analysis

Step 7: Analysing the campaign results

I reviewed the GoPhish dashboard and campaign list to assess the recorded activity. The dashboard screenshot supplied with my evidence document displays aggregate figures of five emails sent, three emails opened, three links clicked, zero data submissions and zero emails reported.

Dashboard metric	Recorded result	Rate (denominator)
Emails sent	5	5/5 = 100% of campaign entries
Emails opened	3	3/5 = 60% of emails sent
Links clicked	3	3/5 = 60% of emails sent
Data submitted	0	0/5 = 0% of emails sent
Emails reported	0	0/5 = 0% of emails sent

The dashboard is an aggregate view and the campaign list contains multiple campaign entries. For that reason, I have treated the five entries as campaign records, not automatically as five different employees. Three entries recorded an email opening and a link click, while two recorded no opening or click. The two non-interacting entries may represent recipients who ignored or recognised the message, but the dashboard alone cannot establish their reason for not interacting.

Denominators: every rate in this report uses the 5 emails sent (campaign entries) as its denominator. Measured against the 3 emails opened, the click figure is 3/3 (100%), but that ratio is only meaningful if opens are reliably recorded, which they are not (image blocking and mail previews distort open tracking). The five entries are repeated sends to the same test mailbox.

Step 8: Triage and Risk Assessment

The aggregate results show that 3 out of 5 campaign entries (60%) recorded a link click. This is a useful indicator of interaction with the simulated message and landing page. It confirms that the tracking and landing-page workflow functioned. Because I opened the tracking link myself from the Mailtrap view, the figure demonstrates the mechanism rather than the behaviour of independent recipients. However, the sample is very small and should not be used to estimate the phishing susceptibility of an entire organisation.

No data submissions were recorded on the dashboard. This means the exercise did not record a successful submission event, even though the landing page was configured to record submission events. The absence of a submission should not be interpreted as proof that a real organisation's users would never disclose credentials.

The absence of reported emails is also worth noting. The dashboard recorded no reports, so the exercise did not demonstrate a reporting action by the test recipients. A future awareness exercise could assess whether users know how to report suspicious messages through the organisation's approved reporting route.

Phishing risk assessment table (denominator for all rates: 5 emails sent):

Metric	Result and rate	Risk interpretation	Limitations	Recommended control
Emails sent	5 sent; 5/5 = 100% delivered to the sandbox	Confirms the delivery and tracking path worked. Not a risk indicator.	Delivery to a Mailtrap sandbox says nothing about how real mail filters would treat the message.	Test against production filtering in an authorised exercise; maintain SPF, DKIM, DMARC and URL protection.
Emails opened	3 opened; 3/5 = 60%	The message prompted opening in the lab, which indicates engagement with the theme.	Open tracking is unreliable, and entries may not be distinct people.	Do not rely on opens alone; track clicks, submissions and reports together.
Links clicked	3 clicked; 3/5 = 60% of sent (3/3 of opened)	Shows the link and landing page worked as designed. Moderate indicative interaction at most.	I opened the tracking link manually from Mailtrap, so this validates the mechanism, not recipient behaviour.	Awareness training on checking links and sender addresses; repeat with an authorised, wider population.
Data submitted (dummy)	0 submitted; 0/5 = 0%	No submission event recorded. This cannot be read as proof that real users would not submit credentials.	Single-tester lab; no independent users were asked to submit anything.	MFA, preferably phishing-resistant for privileged accounts, to limit the impact of any credential disclosure.
Emails reported	0 reported; 0/5 = 0%	No reporting behaviour was demonstrated.	No report button or reporting route was part of the lab.	Deploy a simple report-phishing button and measure the reporting rate.

Step 9: Executive Summary and Recommendations

To: CISO / Head of Information Security / Executive Management
From: GRC Audit Team
Subject: Results of Q3 Controlled Phishing Simulation and Human Risk Assessment
Date:

Scope: one controlled laboratory campaign on a local Kali Linux machine, using GoPhish, a Mailtrap email sandbox, a mailbox I control, fictional identities and a fictional training login page. No real users or credentials were involved.

Method: a simulated VPN password-expiry email linked to a fictional landing page. Delivery, opens, clicks, dummy form submissions and reports were recorded by GoPhish.

Key findings: 5 emails sent; 3 opened (60%); 3 clicked (60%); 0 dummy submissions (0%); 0 reported (0%). All rates use 5 emails sent as the denominator. The links were opened by the tester, so the results validate the simulation workflow and do not measure real user behaviour.

Business implications: this sample is far too small to show that the organisation's training or email controls are ineffective, or that they are effective. It does show that a plausible VPN-themed message can be built and tracked cheaply, and that no reporting route was exercised. Those are the gaps worth closing before a wider, authorised exercise.

Prioritised recommendations:

1. Priority 1 (high): Provide an easy-to-use phishing-reporting mechanism and monitor reporting rates alongside open and click rates.
2. Priority 2 (high): Use multi-factor authentication, preferably phishing-resistant methods for privileged and high-risk accounts, to reduce the impact of stolen credentials.
3. Priority 3 (medium): Continue regular, proportionate phishing-awareness training using realistic examples and clear guidance on reporting suspicious messages.
4. Priority 4 (medium): Maintain email-domain protections and filtering, including SPF, DKIM and DMARC, alongside URL and attachment protection.
5. Priority 5 (planned): Repeat simulations periodically with an appropriately authorised and sufficiently broad test population, and compare results over time.

6. Challenges Encountered and How I Resolved Them

Understanding the Kali network interfaces

Kali displayed more than one network interface, including a NAT address (192.168.233.128) and a host-only address (192.168.164.128). I initially had to distinguish which address was relevant to the local lab and how the virtual machines were connected. I checked the interface addresses rather than assuming that every address shown was interchangeable.

Interpreting the GoPhish 404 response

When I tested the root address of the phishing server, the browser or curl returned a 404 response. I initially treated this as a possible service failure. The troubleshooting clarified that the root URL by itself did not contain a campaign tracking identifier. The tracking link generated for the campaign included a unique rid value and was the correct URL to test.

Configuring the campaign URL

The campaign form required a URL. An earlier campaign attempt did not have a usable base URL, so the message did not contain a complete tracking destination. I then configured the local URL for the same-Kali test and preserved the earlier campaign record rather than deleting it.

Opening the tracking link from Mailtrap

The complete tracking link appeared as text in the Mailtrap email view rather than as a clickable link. I copied the full URL, including the rid parameter, and pasted it into a new Firefox tab inside Kali. This allowed GoPhish to register the click.

Verifying that the campaign had worked

I returned to the GoPhish campaign results and confirmed that the email had been sent, opened and clicked. Seeing the interaction recorded in the dashboard was an important point in the practical because it confirmed that the tracking process was functioning.

7. Lessons Learned and Personal Reflection

This practical helped me understand that a phishing simulation involves more than writing an email and sending it. The sending profile, recipient group, landing page, campaign URL and tracking identifier all need to work together. I also learned to investigate network configuration and application responses before concluding that a service is unavailable.

From a GRC perspective, the exercise reinforced the importance of defining an authorised scope, keeping evidence, interpreting metrics carefully and distinguishing observed behaviour from assumptions about user intent. The dashboard figures are useful evidence, but the small test population limits the conclusions that can be drawn.

8. Conclusion

I completed the GoPhish setup, configured Mailtrap, created the simulated VPN landing page and email template, defined the test group, launched the campaign and reviewed the dashboard results. The main technical challenge was ensuring that the campaign used a complete tracking URL and then opening that URL from the test environment. The exercise provided practical experience in phishing simulation and in translating technical results into GRC observations and recommendations.

9. Screenshot Evidence

The following screenshots are taken from the evidence document supplied with the practical. Captions describe the activity shown. Where a screenshot is supporting evidence rather than proof of a completed configuration, it is labelled accordingly.

Evidence 1

Working in the GoPhish lab directory in Kali Linux.



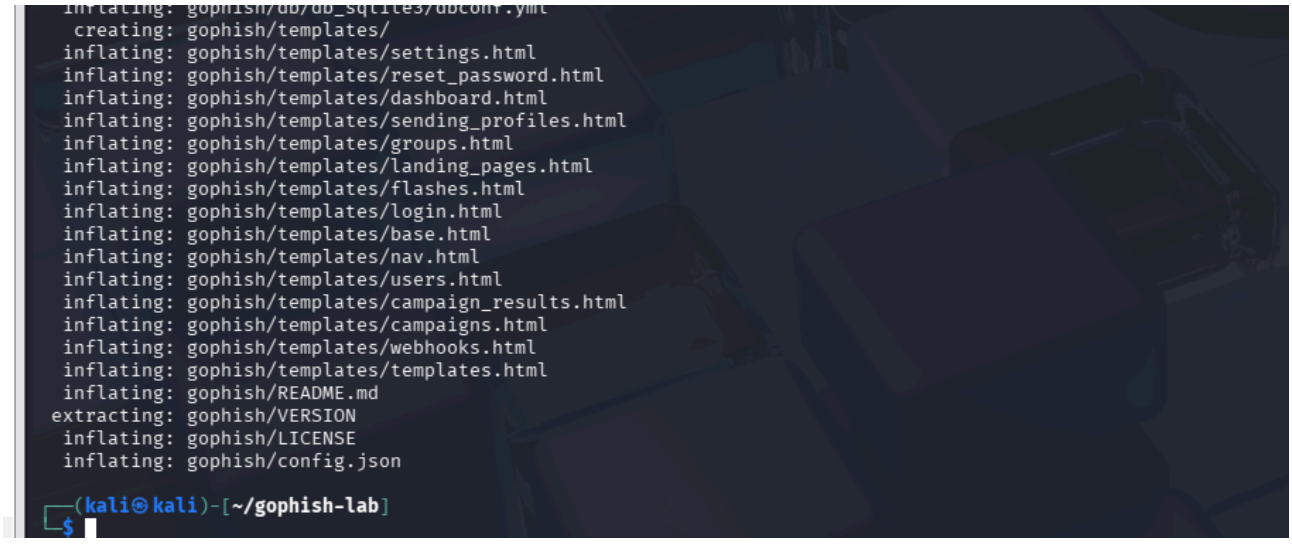
Evidence 2

Starting and checking the GoPhish application from the Kali terminal.



Evidence 3

Extracting the GoPhish application files.



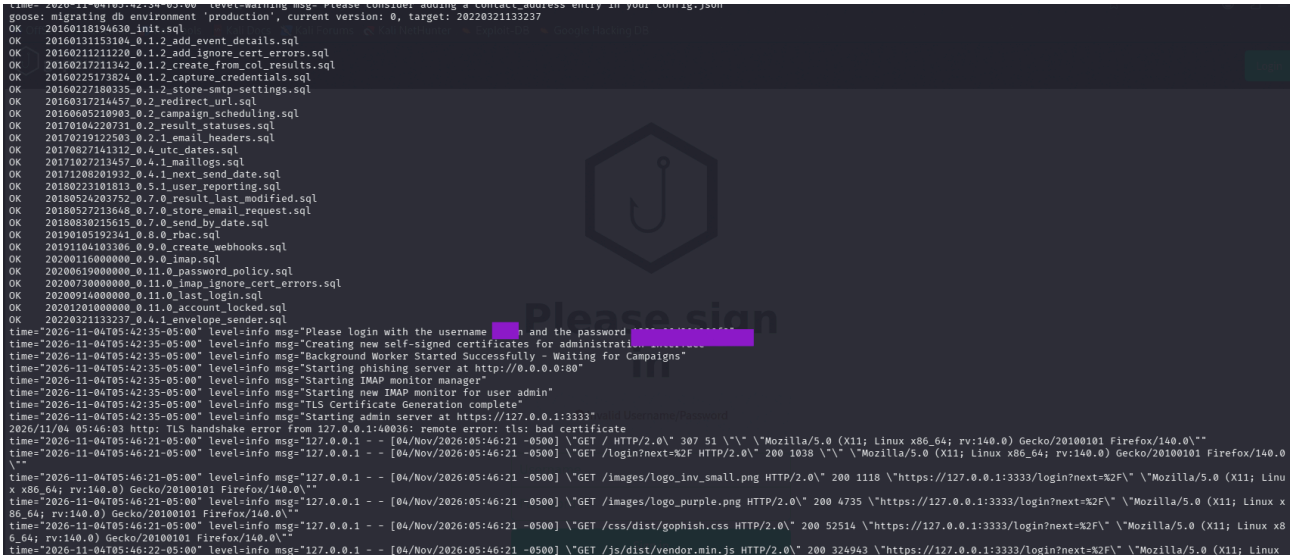
Evidence 4

Terminal evidence from the GoPhish setup and service checks.



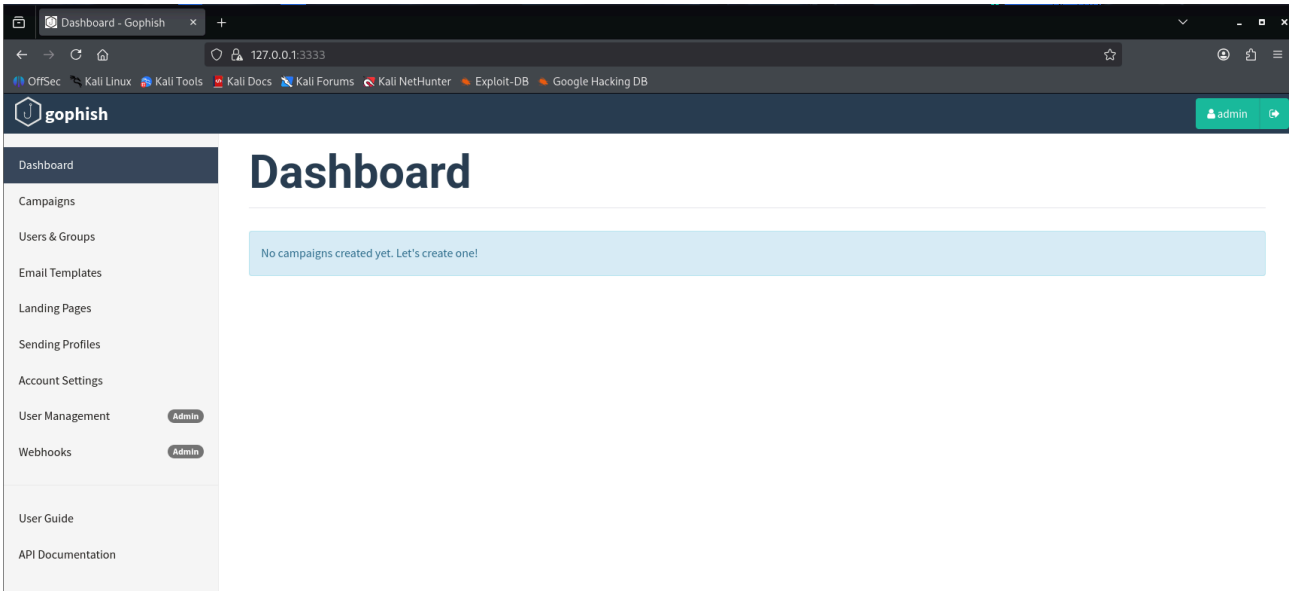
Evidence 5

Further terminal output during the lab setup.



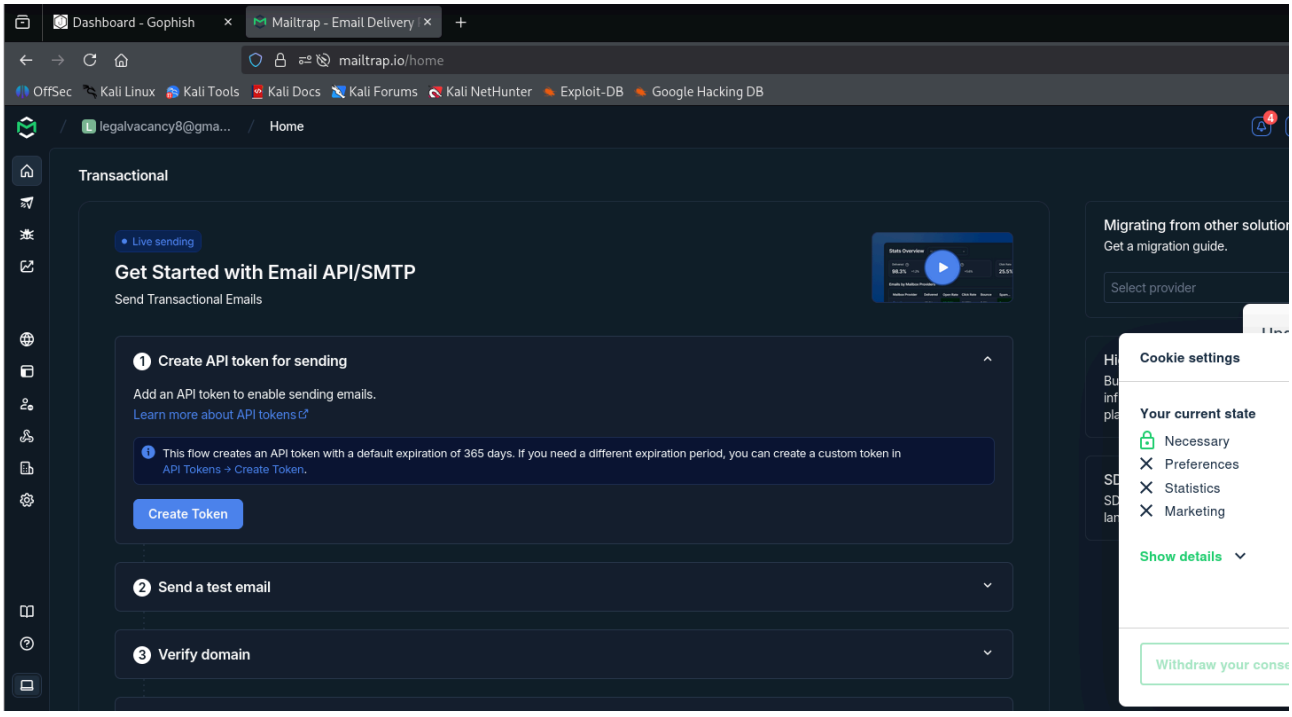
Evidence 6

Accessing the GoPhish web interface.



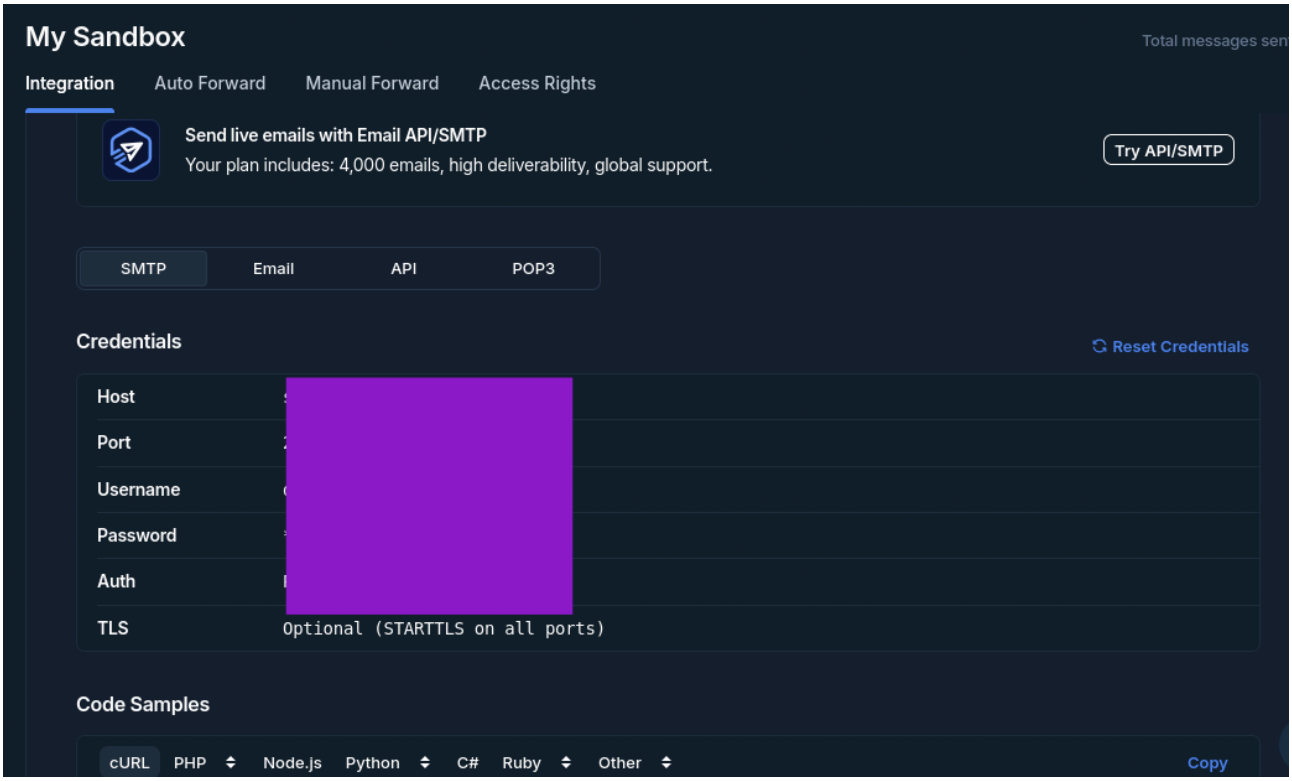
Evidence 7

Supporting screenshot from the GoPhish practical.



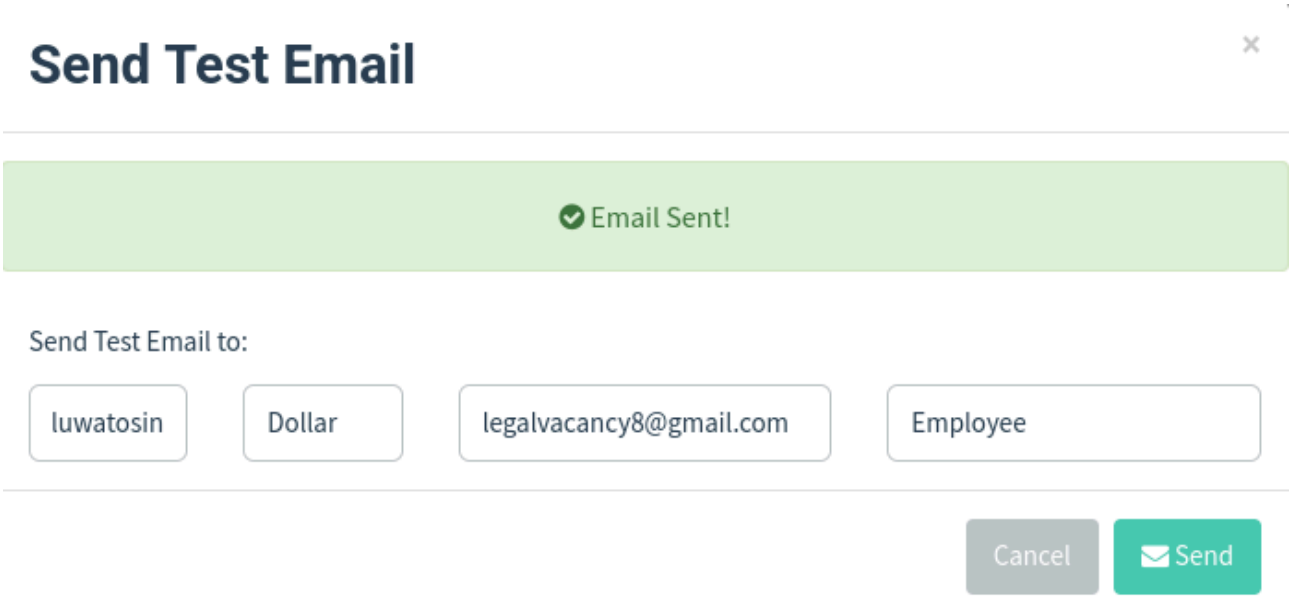
Evidence 8

Mailtrap sandbox and SMTP account details used for the test setup.



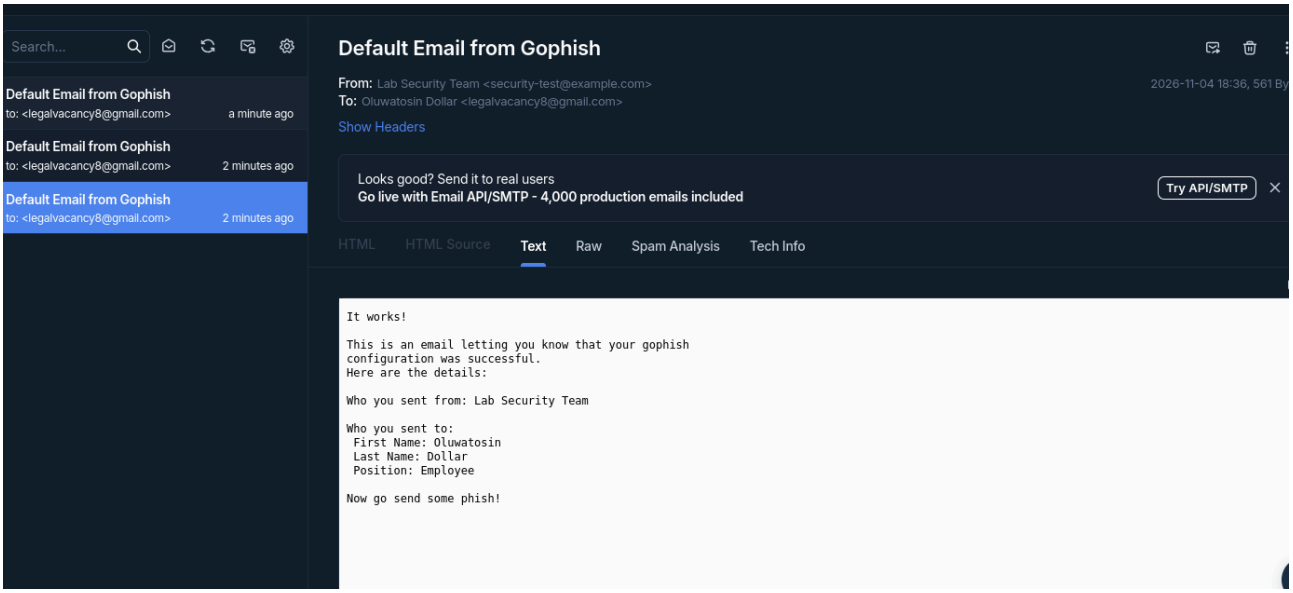
Evidence 9

GoPhish test-email function confirming successful delivery.



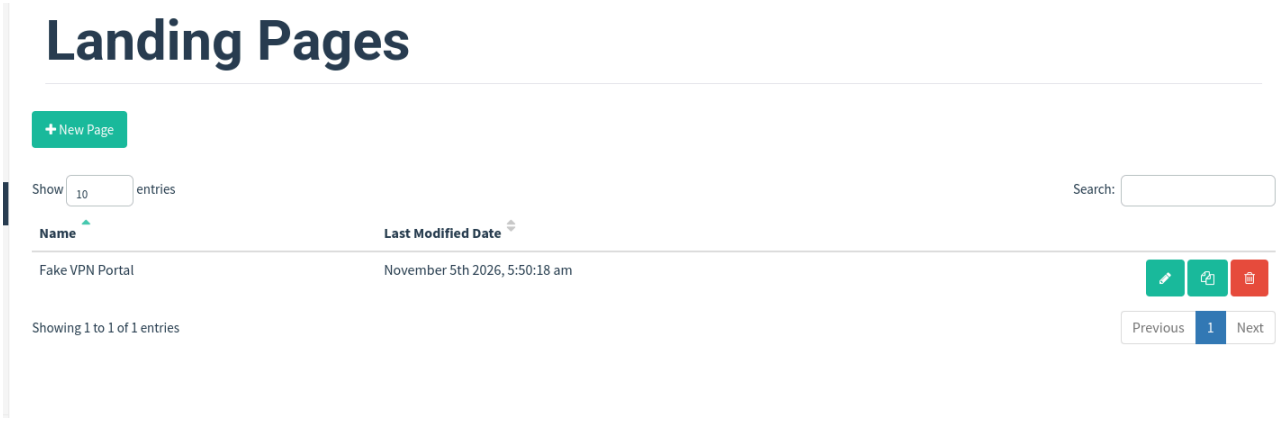
Evidence 10

Mailtrap test inbox displaying the received GoPhish email.



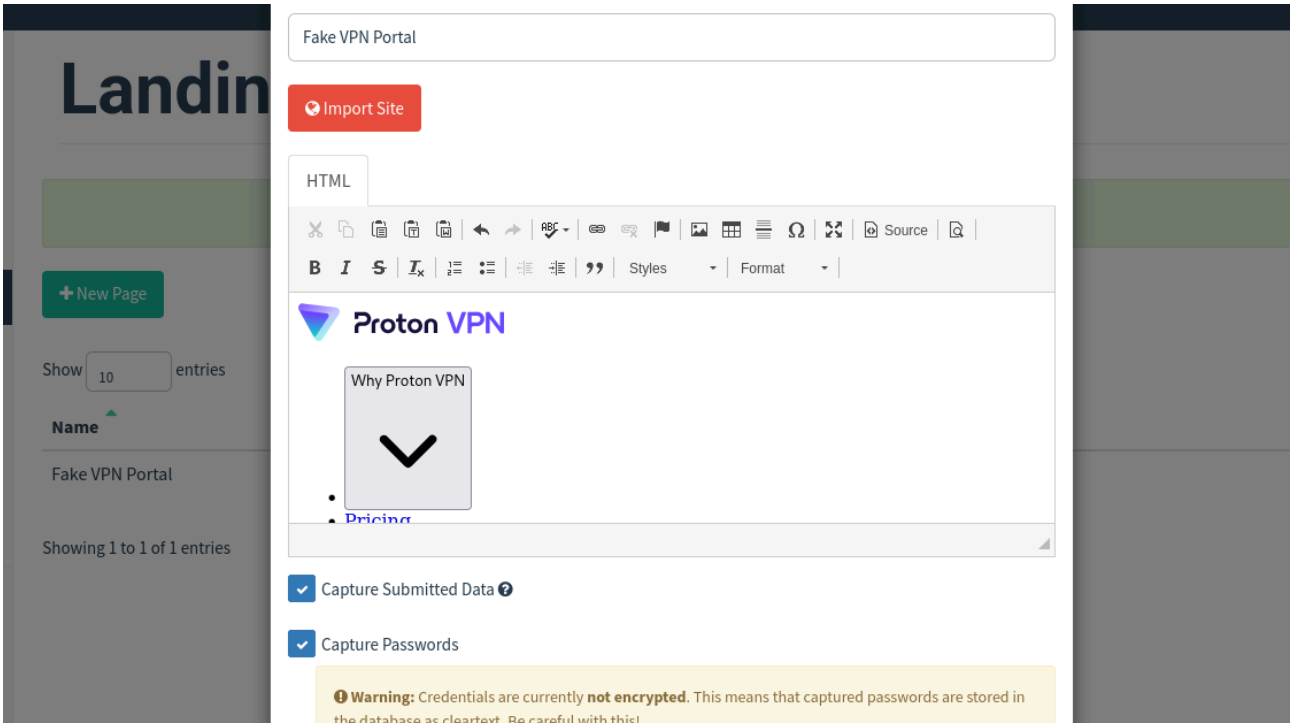
Evidence 11

Landing Pages area in GoPhish.



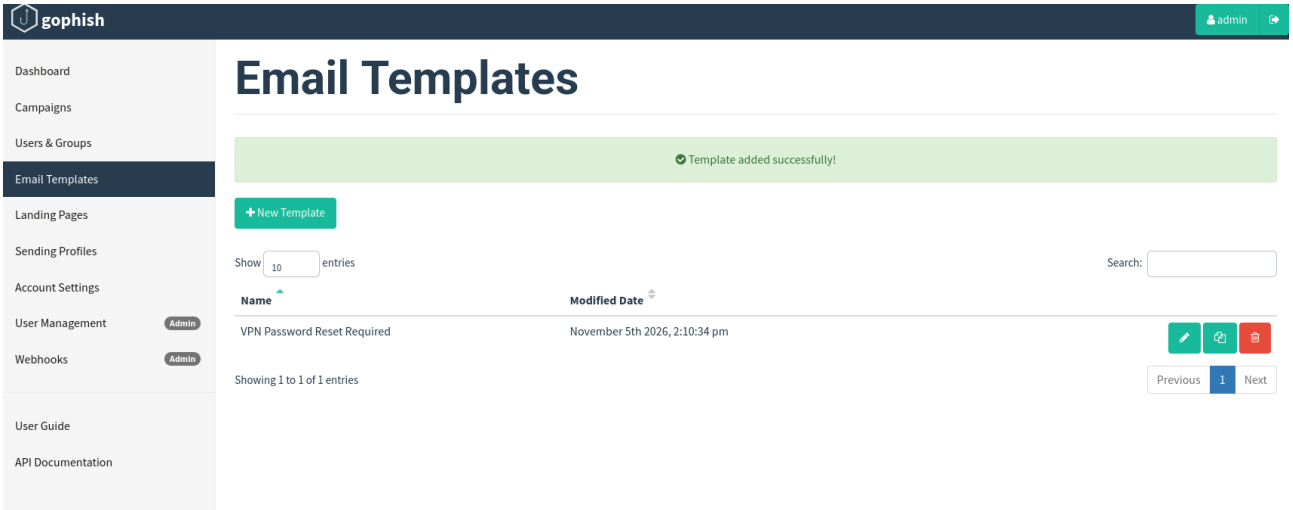
Evidence 12

Creating the simulated VPN landing page and configuring its capture options.



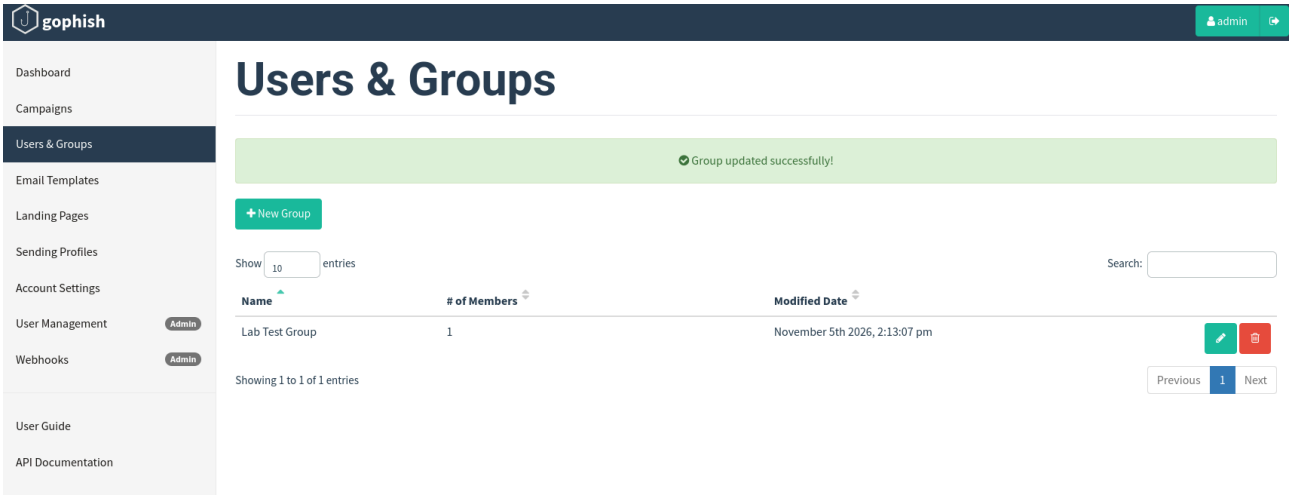
Evidence 13

Saved GoPhish email template.



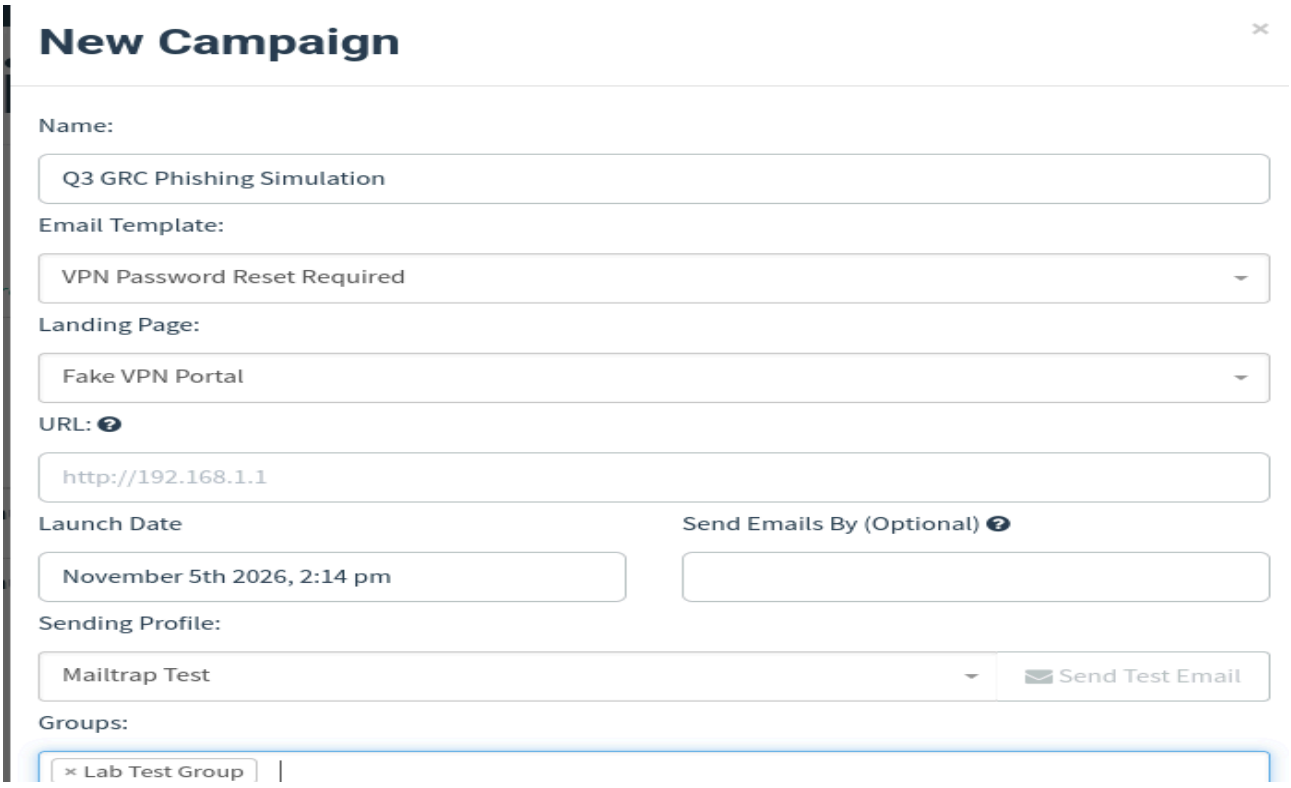
Evidence 14

Saved Lab Test Group in GoPhish.



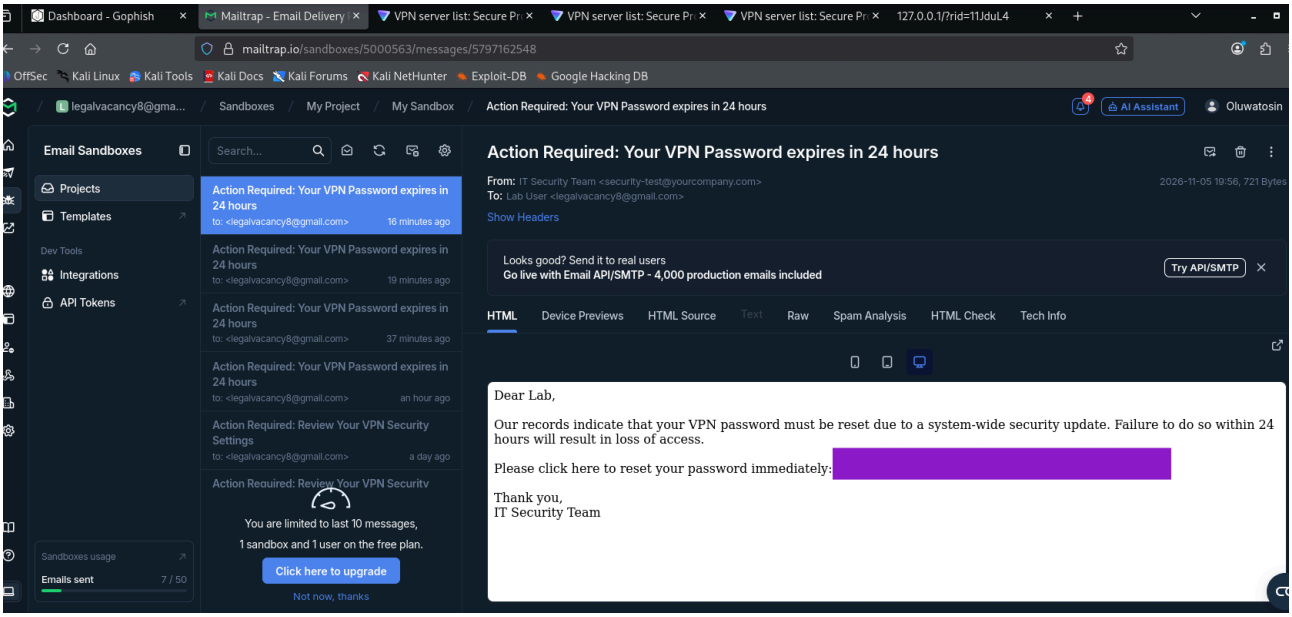
Evidence 15

New Campaign configuration screen.



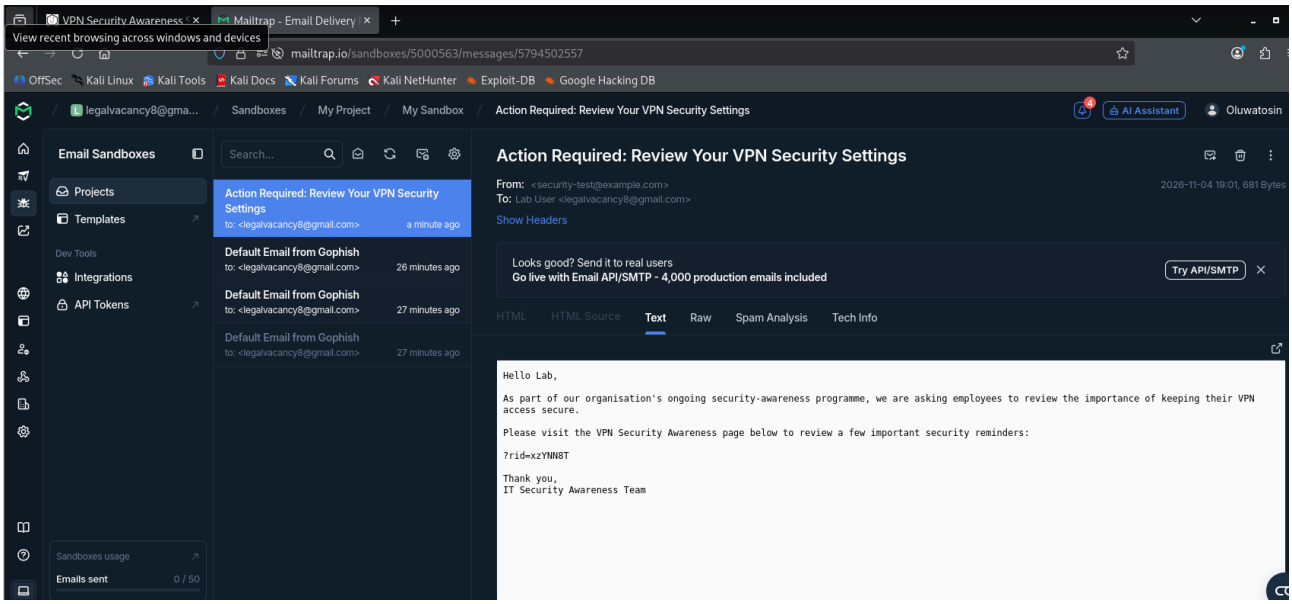
Evidence 16

Received simulated VPN password-reset email in the Mailtrap inbox.



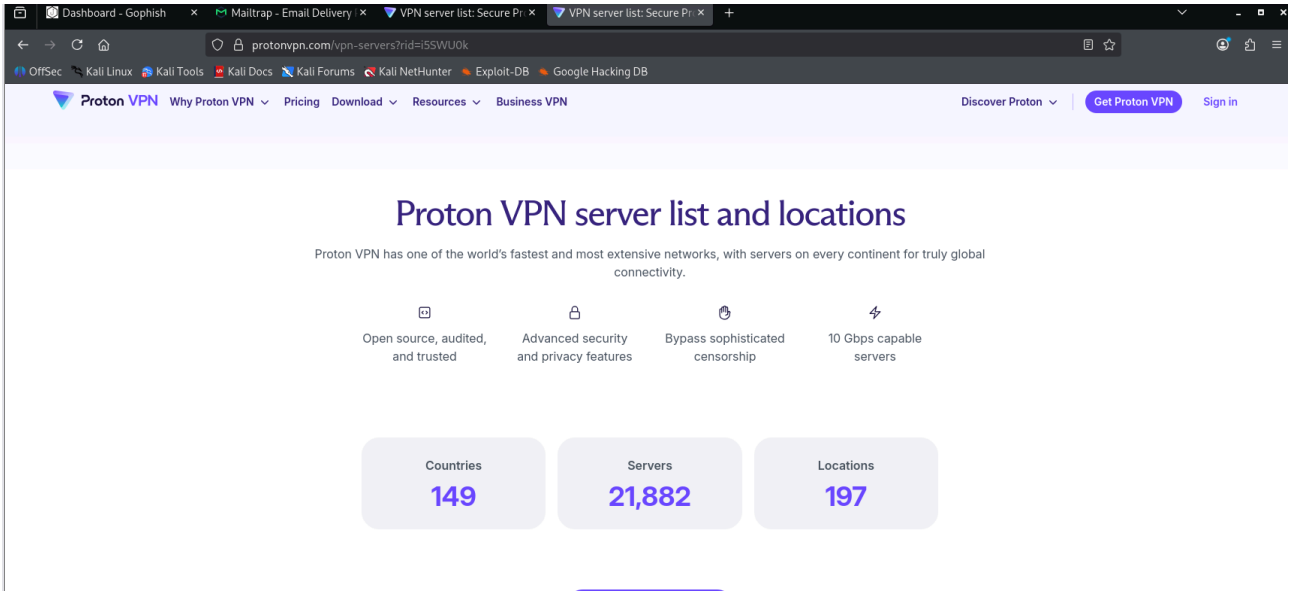
Evidence 17

Email template content and phishing-link placeholder.



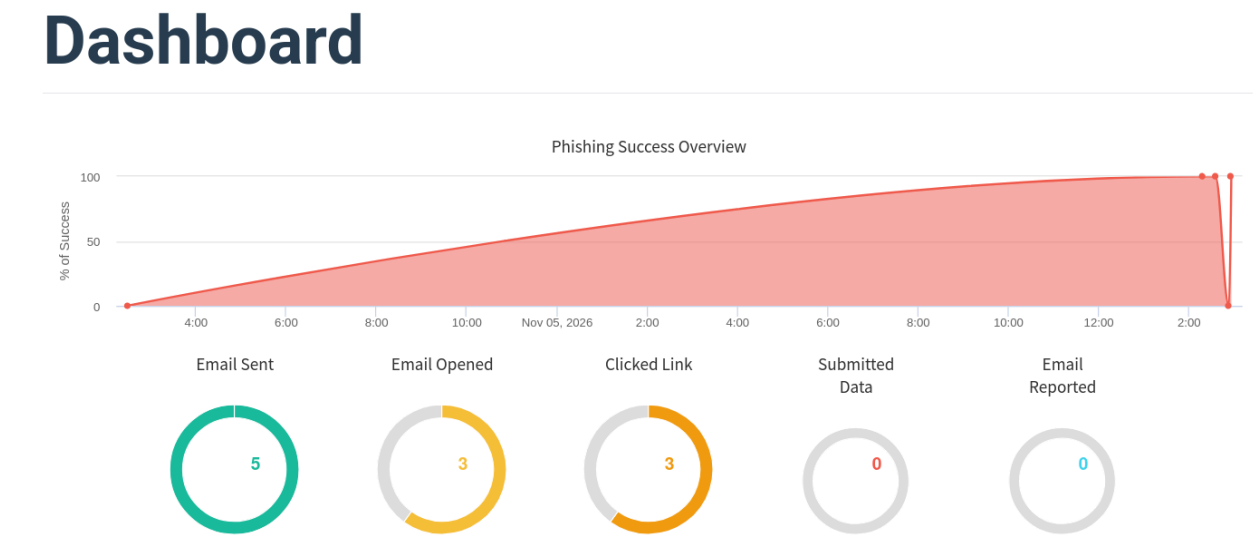
Evidence 18

VPN-themed landing page displayed in the browser.



Evidence 19

GoPhish dashboard showing aggregate campaign results.



Evidence 20

Campaign list showing the recorded Q3 GRC Phishing Simulation entries.

Show 10 entries Search:

Name	Created Date						Status	
Q3 GRC Phishing Simulation	November 5th 2026, 2:56:07 pm	1	1	1	0	0	In progress	
Q3 GRC Phishing Simulation	November 5th 2026, 2:52:57 pm	1	0	0	0	0	In progress	
Q3 GRC Phishing Simulationn	November 5th 2026, 2:34:49 pm	1	1	1	0	0	In progress	
Q3 GRC Phishing Simulation	November 5th 2026, 2:17:24 pm	1	1	1	0	0	In progress	
VPN Security Awareness Simulation 2	November 4th 2026, 2:28:53 pm	1	0	0	0	0	In progress	

Showing 1 to 5 of 5 entries Previous 1 Next

Evidence 21

Dashboard and recent campaign overview.

Dashboard



Recent Campaigns

